

Report on
Cyber Attack Planning & Reconnaissance

Department of Information Technology

By

Pronay Das 12200222006

Class Roll No. - 14

8th Semester

Course Code: DEC-IT 801B

Course Name: Cyber Law and Ethics

St. Thomas' College of Engineering and
Technology, Kolkata

Affiliated to

Maulana Abul Kalam Azad University of
Technology, West Bengal

Session: 2025-26

SET-1 :- Cyber Attack Planning & Reconnaissance

Q.1) A financial company notices that before a ransomware attack, several employees received suspicious emails and unknown login attempts were detected from foreign IP addresses.

Analyze the possible pre-attack plans used by criminals. Identify and explain at least four stages involved in this attack preparation.

⇒ Analysis of Pre-Attack Planning: Ransomware Preparation

In a sophisticated ransomware attack, criminals do not strike randomly; they follow a structured methodology often referred to as the Cyber Kill Chain. The suspicious emails and foreign logins indicate the attackers were in the "Weaponization" and "Delivery" phases after conducting deep research.

1. Reconnaissance (Information Gathering) :-

This is the functional stage where attackers harvest information about the financial company.

- Active vs Passive: Attackers likely used passive Reconnaissance (port scanning to find the foreign IP entry points).
- Purpose: To identify high-value targets (like IT admins or finance managers) who have access to critical databases, making the "suspicious emails" more likely to be opened.

2. Weaponization & Phishing (The "suspicious Emails") :-

Once targets are identified, attackers create a "vessel" for the ransomware.

~~super~~ • Spear Phishing: The emails mentioned are likely spear-phishing attempts - highly targeted messages designed to look like internal corporate communication.

• Payload: These emails usually contains a malicious link or an ~~attempts~~ attachments (like a fake invoice, pdf) containing a Trojan. When an employee clicks, it creates a "backdoor" for the attacker to enter the network.

3. Scanning and Vulnerability Research (The "Unknown Login") :-

The detection of foreign IP addresses indicates that attackers were testing the company's perimeter.

• Credential stuffing/Brute Force: The unknown login attempts suggest the attackers were trying to use leaked passwords or brute-force common credentials to gain access to the Remote Desktop Protocol (RDP) or VPN.

• Purpose: They are looking for the "path of least resistance." A single successful login from a foreign IP allows them to bypass the firewall and begin the internal infection.

4. Gaining Access and Lateral Movement :-

This is the final preparation stage before the actual "encryption" of files begins.

• Establishing a Foothold: After a successful login or phishing click, the attacker install a command and control (C2) tool.

• Lateral Movement: The attacker moves from the initial compromised workstation to the central server. They "scout" the network to find where the most sensitive financial data and - crucially - the backups are located, to ensure the company has no choice but to pay.

Q.2) A hacker collected employee details from LinkedIn and the company website before launching a phishing campaign.

Analyze how reconnaissance and social engineering contributed to the success of the attack, suggest two preventive measures based on your analysis.

⇒ Analysis of Reconnaissance and Social Engineering

In the provided scenario, the hacker followed a classic "social engineering *kill chain". Here is the breakdown of how these two elements synergized to compromise the target.

1. The Role of Reconnaissance (Information Gathering):-

Reconnaissance is the "research" phase. By using LinkedIn and the company website, the hacker performed passive Reconnaissance (gathering data without directly interacting with the company's servers, making it undetectable).

- Mapping the Hierarchy: LinkedIn allows attackers to identify "High-value Targets" (HVTs) such as System Administrators or Financial officers. It also reveals reporting structures.

- Email Pattern Discovery: By finding a few official emails on the website, hackers can deduce the company's email format, allowing them to target any employee found on LinkedIn.

2. The Success of Social Engineering:-

Social engineering is the heart of human hacking. Once the reconnaissance data is collected, it is used to exploit human psychology rather than software vulnerabilities.

- **The Power of Personalization (Spear Phishing):** Because the hacker knows the employee's name, job title, and current projects from LinkedIn, the phishing email isn't a generic "Hello Here". Instead, it might say "Hi [Name], regarding the [Project Name] discussed on the website, please review this updated timeline."
- **Exploiting Trust and Authority:** If the hacker identifies a manager on LinkedIn, they can spoof that manager's identity. An employee is far more likely to click a malicious link if they believe it comes from their direct supervisor.

Preventive Measures:-

Based on the analysis of how the information was weaponized, the following are critical.

(i) Implementation of "Digital Footprint" Policies & Privacy Training:-

- **Action:** Employees should be trained to sanitize their LinkedIn ~~their~~ profiles (e.g., not listing specific software versions or internal project codes).
- **Goal:** To reduce the "Attack Surface" by making it harder for hackers to conduct successful passive reconnaissance.

(ii) Multi-Factor Authentication (MFA) & Phishing Simulations

- **Action:** Enforce hardware-based or app-based MFA for all corporate logins. Additionally, run where the company sends fake phishing emails to employees.
- **Goal:** If an employee is socially engineered into giving away their password, MFA prevents the hacker from actually entering the system.